03CIT4067 • GROUP 7 • TOPIC 15

Security Testing & Remediation: OWASP A05 & A10

Phase 2 Vulnerability Assessment, System Hardening, and Logging Framework

EXECUTIVE OVERVIEW

Core Security Objectives

OWASP A05: Misconfiguration

Elimination of debug endpoints, suppression of server headers, and enforcement of security policies.

PRIORITY 01

OWASP A10: Logging Failures

Integration of centralized security logging to record authentication and authorization events.

PRIORITY 02

Fail-Closed Architecture

Safe error handling preventing stack trace leaks during application exceptions.

PRIORITY 03

RISK ANALYSIS

A05: Security Misconfiguration Identified

- **Active Debug Mode:**
  Flask running with interactive debugger exposed on failure.
- **Verbose Server Banners:**
  Werkzeug headers revealing exact framework version numbers.
- **Missing Protection Headers:**
  No clickjacking or content-type enforcement present.

IMPACT ASSESSMENT

High Risk of Information Disclosure

Exposed stack traces permit attackers to reconstruct internal file systems and target known framework exploits.

REMEDIATION EXECUTED

A05: System Hardening Applied

Debug Flag Disabled

`DEBUG = False`

Enforced strict environment separation for staging and production runs.

HTTP Headers Added

`X-Frame-Options: SAMEORIGIN`

Suppressed server fingerprints and protected against clickjacking attacks.

Fail-Closed Handlers

`@app.errorhandler(500)`

Generic response pages render without exposing raw stack traces.

RISK ANALYSIS

A10: Logging & Monitoring Blind Spots

- **Unrecorded Auth Failures:**
  Failed login attempts generated no persistent audit records.
- **Missing Request Context:**
  Lack of client IP tracking and timestamps across server logs.
- **Zero Forensics Capability:**
  Inability to reconstruct active brute-force or privilege escalations.

OPERATIONAL VULNERABILITY

Delayed Attack Detection

Without security event logs, automated credential attacks operate entirely undetected by system administrators.

REMEDIATION EXECUTED

A10: Structured Audit Logging Integrated

1. Audit Event Capture

Logs record failed log-ins, password changes, and access violations.

2. Rich Metadata Context

Timestamp, client IP, route, and HTTP method recorded automatically.

3. Credential Masking

Strict sanitization prevents passwords or session tokens in log files.

PHASE 2 CONCLUSION

System Posture Hardened Successfully

Zero configuration leaks exposed and complete security audit logging operational across core routes.

NEXT STEP: CI/CD Security Integration